

CompTIA Security+ SY0-701 Cheat Sheet

A chapter-wise quick reference covering all 16 lessons of the Security+ CertMaster Study Course, aligned to the SY0-701 exam objectives (v2.0).

How to Use This Cheat Sheet

This is a revision aid, not a substitute for the lesson content. Each chapter lists:

- **Maps to:** the exam objective domains covered
- **Key concepts:** the must-know terms, models, and acronyms
- **Remember:** the easy-to-confuse items and exam traps

Tip: The exam is 12 percent General Concepts, 22 percent Threats/Vulns/Mitigations, 18 percent Architecture, 28 percent Operations, and 20 percent Program Management. Allocate revision time accordingly.

Lesson 1: Summarising Fundamental Security Concepts

Maps to: 1.1 (Security Controls), 1.2 (Fundamental Concepts)

The CIA Triad

- **Confidentiality:** information is only accessible to authorised parties (encryption, access control)
- **Integrity:** information has not been altered without authorisation (hashing, digital signatures)
- **Availability:** authorised users can access information when needed (redundancy, backups)

Beyond CIA

- **Non-repudiation:** the sender cannot deny having sent a message (digital signatures, audit logs)
- **Authenticity:** the source is genuine

AAA Framework

Term	What it answers	Examples
Authentication	Who are you?	Password, MFA, certificate
Authorisation	What are you allowed to do?	ACL, RBAC, ABAC

Term	What it answers	Examples
Accounting	What did you do?	Audit logs, SIEM

Also: AAA servers (RADIUS, TACACS+, Diameter) centralise these functions.

Security Control Categories (the "who or what implements it")

Category	Implemented by	Example
Technical	Hardware/software	Firewall, IDS, encryption
Managerial	Policies, risk programme	Risk assessments, SDLC policy
Operational	People-led processes	Awareness training, access reviews
Physical	Tangible barriers	Fences, locks, bollards, CCTV

Security Control Functional Types (the "what it does")

Type	Purpose	Example
Preventive	Stop incidents before they occur	Firewall, MFA, locks
Detective	Identify incidents in progress or after	IDS, SIEM alerts, CCTV review
Corrective	Fix damage after an incident	Patching, backup restore
Deterrent	Discourage threat actors	Warning signs, visible cameras
Compensating	Substitute when primary control is infeasible	Manual review when an automated control fails
Directive	Tell users what to do	Acceptable Use Policy

Gap Analysis

The exercise of comparing the **current state** vs the **desired state** of security maturity, mapped to a framework (e.g. NIST CSF, ISO 27001, Essential Eight in AU context).

Zero Trust (Never trust, always verify)

- **Control plane** components: Adaptive identity, Threat scope reduction, Policy-driven access control, Secured zones
- **Data plane** components: Subject/system, Policy Engine, Policy Administrator, Policy Enforcement Point (PEP)

Physical Security Quick Hits

- **Bollards:** stop vehicles
- **Access control vestibule (mantrap):** prevents tailgating
- **Sensors:** Infrared (heat), Pressure (weight), Microwave (motion via radio), Ultrasonic (sound waves)

Deception & Disruption

- **Honeypot:** decoy system
- **Honeynet:** decoy network
- **Honeyfile:** decoy file with alerting
- **Honeytoken:** fake credential/record that triggers an alert if used

Remember: Categories $\neq$ Types. A camera is a **physical** control that can be **detective** (recording) and **deterrent** (visible).

Lesson 2: Compare Threat Types

Maps to: 2.1 (Threat Actors), 2.2 (Attack Surfaces), 2.3 (Social Engineering)

Vulnerability, Threat, Risk

- **Asset:** something of value
- **Vulnerability:** a weakness
- **Threat:** a potential cause of harm
- **Risk:** probability x impact of a threat exploiting a vulnerability

Threat Actor Attributes

- **Internal vs external**
- **Resources/funding** (low to nation-state)
- **Level of sophistication/capability** (script kiddie to APT)

Threat Actor Types

Actor	Motivation	Sophistication
Unskilled attacker (script kiddie)	Curiosity, notoriety	Low
Hacktivist	Political/ideological	Low to medium

Actor	Motivation	Sophistication
Organised crime	Financial gain	High
Nation-state / APT	Espionage, war, disruption	Very high
Insider threat	Revenge, financial, ideology	Varies
Shadow IT	Convenience (not malicious)	N/A

Motivations

Data exfiltration, espionage, service disruption, blackmail, financial gain, philosophical/political beliefs, ethical, revenge, disruption/chaos, war.

Threat Vectors & Attack Surfaces

- **Message-based:** Email, SMS, IM
- **Image-based, File-based, Voice call**
- **Removable device:** USB drops
- **Vulnerable software:** Client-based vs agentless
- **Unsupported systems and applications**
- **Unsecure networks:** Wireless, Wired, Bluetooth
- **Open service ports**
- **Default credentials**
- **Supply chain:** MSPs, vendors, suppliers

Social Engineering Techniques

Technique	Description
Phishing	Mass email lure
Spear phishing	Targeted phishing
Whaling	Targeting executives
Vishing	Voice phishing
Smishing	SMS phishing
Pharming	Redirect to fake site (often via DNS)
Impersonation	Pretending to be someone
Pretexting	Fabricated scenario to extract info

Technique	Description
Watering hole	Compromise a site the target visits
Typosquatting	Lookalike domains (goooogle.com)
Business Email Compromise (BEC)	Spoofed executive emails requesting wire transfers
Brand impersonation	Faking a trusted brand
Misinformation/disinformation	False narratives

Remember: Phishing is the umbrella term; vishing, smishing, whaling are variants by channel or target.

Lesson 3: Explain Cryptographic Solutions

Maps to: 1.4 (Cryptographic Solutions)

Symmetric vs Asymmetric

	Symmetric	Asymmetric
Keys	One shared secret key	Public + private key pair
Speed	Fast	Slow
Use case	Bulk data encryption	Key exchange, signatures
Algorithms	AES, 3DES, ChaCha20	RSA, ECC, DSA, Diffie-Hellman

Key Lengths (rule of thumb)

- **AES:** 128, 192, 256 bits (use AES-256 by default)
- **RSA:** 2048 bits minimum, 3072+ preferred
- **ECC:** 256 bits offers comparable strength to RSA 3072

Hashing

- Converts input to fixed-size digest; **one-way**
- Validates **integrity**, not confidentiality
- **SHA-256, SHA-3** preferred; **MD5 and SHA-1 are broken**
- **HMAC:** keyed hash for message authentication

Digital Signatures

- Hash the message, then encrypt the hash with the sender's **private key**
- Provides: integrity, authentication, **non-repudiation**

Salting & Key Stretching

- **Salt**: random value added to a password before hashing (defeats rainbow tables)
- **Key stretching**: repeatedly hashing to slow brute force (PBKDF2, bcrypt, scrypt, Argon2)

Public Key Infrastructure (PKI)

- **CA (Certificate Authority)**: issues and vouches for certificates
- **RA (Registration Authority)**: verifies identity before CA issues
- **CSR (Certificate Signing Request)**: request you submit to a CA
- **CRL (Certificate Revocation List)**: list of revoked certs
- **OCSP**: real-time revocation status check (lighter than CRL)
- **Root of trust**: the trusted CA at the top of the chain

Certificate Types

- **Self-signed**: for internal use only
- **Wildcard** (*.example.com): covers all subdomains
- **SAN (Subject Alternative Name)**: multiple domains in one cert
- **EV (Extended Validation)**: highest assurance

Cryptographic Hardware

- **TPM (Trusted Platform Module)**: on-motherboard chip storing keys
- **HSM (Hardware Security Module)**: dedicated appliance, FIPS 140 certified
- **Secure enclave**: isolated processor region (Apple's Secure Enclave)
- **KMS (Key Management System)**: cloud-managed key lifecycle

Other Concepts

- **Perfect Forward Secrecy (PFS)**: session keys cannot be derived even if the long-term key is compromised (DHE, ECDHE)
- **Key escrow**: third party holds copy of key (recovery vs privacy trade-off)
- **Blockchain**: distributed, immutable ledger
- **Obfuscation**: Steganography (hide in plain sight), Tokenisation (substitute with token), Data masking (XXX-XX-1234)

Remember: Encryption protects confidentiality; hashing protects integrity; signatures provide non-repudiation.

Lesson 4: Implement Identity and Access Management

Maps to: 1.2 (AAA), 4.6 (IAM)

Authentication Factors

Factor	Example
Something you know	Password, PIN
Something you have	Smart card, hardware token
Something you are	Fingerprint, face, iris
Somewhere you are	Geolocation, GPS
Something you do	Behavioural biometrics

MFA uses two or more **different** factors. Two passwords is not MFA.

Biometric Metrics

- **FAR (False Acceptance Rate):** wrong person let in (security risk)
- **FRR (False Rejection Rate):** right person denied (usability risk)
- **CER (Crossover Error Rate):** where FAR equals FRR; lower is better

Authentication Token Types

- **Hard tokens:** physical (YubiKey, RSA SecurID)
- **Soft tokens:** software-generated (Authenticator apps)
- **HOTP:** HMAC-based one-time password (event-based)
- **TOTP:** Time-based one-time password (30 to 60 second window)

Password Best Practices

Length > complexity. Avoid forced regular rotation unless compromise suspected (NIST SP 800-63B guidance). Use a password manager. Move toward **passwordless** (FIDO2, passkeys).

Authorisation Models

Model	How access is granted
DAC (Discretionary)	Owner decides (typical Windows file permissions)
MAC (Mandatory)	System-enforced labels (military, SELinux)
RBAC (Role-based)	Permissions assigned to roles, users assigned to roles
RBAC (Rule-based)	Access via system-enforced rules (e.g. time of day)
ABAC (Attribute-based)	Policies evaluate attributes of subject, object, environment

Other Key IAM Concepts

- **Least privilege:** users have only what they need
- **Separation of duties:** no single user can complete a critical end-to-end task
- **Just-in-Time (JIT):** elevated permissions granted temporarily
- **Privileged Access Management (PAM):** vault privileged credentials, session record, rotate passwords
- **Identity proofing:** verify identity at account creation
- **Attestation:** periodic review and certification of access

Directory Services & Federation

- **LDAP:** directory protocol (port 389; 636 for LDAPS)
- **Kerberos:** ticket-based SSO (used by AD)
- **SAML:** XML-based SSO between identity provider (IdP) and service provider (SP)
- **OAuth 2.0:** authorisation framework (delegated access)
- **OpenID Connect (OIDC):** authentication layer on top of OAuth 2.0
- **Federation:** trust between domains/organisations (cross-org SSO)

Remember: SAML for SSO across enterprises, OAuth for delegated API access, OIDC for user authentication on top of OAuth.

Lesson 5: Secure Enterprise Network Architecture

Maps to: 3.1 (Architecture Models), 3.2 (Secure Infrastructure)

Network Infrastructure Concepts

- **Switching:** Layer 2, MAC-based (VLANs segment)

- **Routing:** Layer 3, IP-based
- **Security zones:** Internet, DMZ/screened subnet, Internal, Trusted, Restricted
- **Physical isolation / air gap:** highest security for OT/ICS

Device Placement & Attributes

- **Inline vs tap/monitor:** inline can block, tap only observes
- **Active vs passive:** active interacts, passive listens
- **Fail-open** (availability) vs **Fail-closed** (security)
- **Jump server:** single hardened entry into a secure zone
- **Sensors:** collect data for IDS/IPS

Firewalls

Type	Operates at	What it inspects
Packet filter	L3/L4	Source/dest IP, port
Stateful	L3/L4	Connection state
Layer 7 / Application	L7	App-layer protocol content
WAF (Web Application Firewall)	L7	HTTP/S for web app attacks (SQLi, XSS)
NGFW (Next-Gen Firewall)	L3-L7	Includes DPI, IDS/IPS, app awareness
UTM (Unified Threat Management)	Multi	Combines firewall, AV, content filter, VPN

IDS vs IPS

- **IDS:** detects and alerts (out-of-band, passive)
- **IPS:** detects and **blocks** (inline)
- Variants: NIDS/NIPS (network), HIDS/HIPS (host)

Detection Methods

- **Signature-based:** match known patterns; misses zero-day
- **Anomaly-based:** baseline deviation; more false positives
- **Heuristic/behavioural**

Load Balancing & Proxies

- **Load balancer:** distributes traffic for performance and availability

- **Proxy server:** intermediary that can cache, filter, anonymise
- **Reverse proxy:** sits in front of servers (security, SSL offload)

Port Security

- **802.1X:** port-based network access control
- **EAP:** Extensible Authentication Protocol (used inside 802.1X)
- **MAC filtering:** weaker (MACs can be spoofed)

Secure Communications

Protocol	Use	Port
TLS	Web traffic, replaces SSL	443 (HTTPS)
IPSec	VPN at IP layer (AH and ESP)	500 (IKE), 4500 (NAT-T)
SSH	Encrypted remote shell	22
RDP	Remote desktop	3389
L2TP/IPSec, SSTP, IKEv2	VPN protocols	varies

SDN, SD-WAN, SASE

- **SDN:** separates control plane and data plane; centralised programmability
- **SD-WAN:** software-managed WAN routing across multiple links
- **SASE:** SD-WAN + cloud security (CASB, SWG, ZTNA, FWaaS) as a service

Remember: WAF defends against application attacks (SQLi, XSS); regular firewalls defend against network attacks.

Lesson 6: Secure Cloud Network Architecture

Maps to: 3.1 (Architecture Models)

Cloud Deployment Models

- **Public:** shared (AWS, Azure, GCP)
- **Private:** single-tenant, dedicated
- **Hybrid:** mix of public and private
- **Community:** shared among similar organisations

Cloud Service Models

Model	What you manage	What provider manages	Example
IaaS	OS, apps, data	Hardware, virtualisation	EC2, Azure VMs
PaaS	Apps, data	OS, runtime, hardware	App Service, Heroku
SaaS	Data (mostly)	Everything else	Microsoft 365, Salesforce
FaaS / Serverless	Function code	Everything else	Lambda, Azure Functions

Shared Responsibility Matrix

You always own **data classification and access**. Provider responsibility grows from IaaS to SaaS. Understand who patches what; getting this wrong creates compliance gaps (often flagged in IRAP, SOC 2, ISO 27001 audits).

Cloud Architecture Concepts

- **Centralised vs decentralised computing**
- **Virtualisation:** hypervisor (Type 1 bare-metal, Type 2 hosted)
- **Containers:** OS-level virtualisation (Docker, Kubernetes); lighter than VMs
- **Infrastructure as Code (IaC):** Terraform, CloudFormation, ARM
- **Microservices:** small, independent services communicating via APIs
- **SDN:** programmable networking
- **VPC (Virtual Private Cloud):** logically isolated cloud network

Cloud Security Considerations

- VM escape and resource reuse vulnerabilities
- Misconfigured object storage (public S3 buckets remain a top cause of breaches)
- Identity sprawl across tenants
- **CASB (Cloud Access Security Broker):** policy enforcement between users and cloud apps

Embedded Systems & ICS

- **Embedded systems:** purpose-built (medical devices, automotive)
- **ICS / SCADA:** industrial control, often using legacy protocols
- **IoT:** internet-connected consumer/enterprise devices
- **RTOS:** real-time OS for time-critical operations
- These typically have **limited patching**, long lifecycles, and require **compensating controls** like segmentation

Zero Trust in the Cloud

- **Deperimeterisation:** the network edge is no longer the defence boundary
- Identity becomes the perimeter
- Every request authenticated, authorised, and encrypted

Remember: In IaaS the customer patches the OS; in SaaS the provider does. Misunderstanding shared responsibility is a top audit finding.

Lesson 7: Explain Resiliency and Site Security Concepts

Maps to: 3.4 (Resilience & Recovery), 1.2 (Physical Security)

Asset Management

- **Asset tracking:** inventory, enumeration, ownership
- **Classification:** public, internal, confidential, restricted/critical
- **Acquisition/procurement:** ensure secure-by-design
- **Disposal:** sanitisation (overwrite), destruction (shred, degauss, incinerate), certification

Data Backups

- **3-2-1 rule:** 3 copies, 2 media types, 1 offsite
- **Types:** Full, Incremental (only changes since last backup), Differential (changes since last full)
- **Snapshots:** point-in-time, often on storage layer
- **Replication:** synchronous (real-time) or asynchronous
- **Journaling:** logs transactions for replay

Continuity & Recovery Metrics

Term	Meaning
RTO (Recovery Time Objective)	How quickly must we recover?
RPO (Recovery Point Objective)	How much data loss is acceptable?
MTTR (Mean Time To Repair)	Average time to fix
MTBF (Mean Time Between Failures)	Reliability measure
MTTF (Mean Time To Failure)	For non-repairable items

High Availability

- **Load balancing:** distribute work, scale horizontally
- **Clustering:** active-active or active-passive failover
- **Geographic dispersion:** multiple regions
- **Platform diversity:** avoid single-vendor failure
- **Multi-cloud:** spread risk across cloud providers

Site Types for Disaster Recovery

Site	Equipment	Data	Time to Resume
Hot	Fully configured	Live or near-live	Minutes
Warm	Partial equipment	Periodic	Hours to days
Cold	Empty facility	None	Days to weeks

Power Resilience

- **UPS:** short-term, battery, smooths over brief outages
- **Generator:** longer-term, fuel-based
- **PDU:** Power Distribution Unit
- **Dual power supplies, A/B feeds**

Testing Resiliency

- **Tabletop exercise:** discussion-based walkthrough
- **Walkthrough/simulation:** scripted scenario
- **Parallel:** stand up DR site alongside production
- **Failover / full interruption:** actually cut over

Physical Security Controls

- **Site layout:** bollards, fencing, lighting (deterrent)
- **Gateways and locks:** mantraps, biometric locks
- **Security guards:** intelligent, adaptable
- **Cameras (CCTV):** detective; PTZ for coverage
- **Alarm systems and sensors:** PIR, microwave, ultrasonic, pressure
- **Defence in depth:** layered controls

Remember: RTO is **time to recover**; RPO is **data loss tolerance**. Lower RPO requires more frequent backups or replication.

Lesson 8: Explain Vulnerability Management

Maps to: 2.3 (Vulnerabilities), 4.3 (Vulnerability Management)

Vulnerability Categories

Category	Examples
Application	Memory injection, buffer overflow, race conditions (TOC/TOU), malicious update
OS-based	Unpatched OS, misconfiguration
Web-based	SQL injection (SQLi), Cross-site Scripting (XSS), CSRF
Hardware	Firmware bugs, end-of-life, legacy
Virtualisation	VM escape, resource reuse
Cloud-specific	Misconfigured storage, IAM sprawl
Supply chain	Compromised vendor, malicious library
Cryptographic	Weak ciphers, key reuse, broken hashes
Misconfiguration	Default credentials, open ports
Mobile	Sideloaded, jailbreaking, rooting
Zero-day	Unknown vulnerability, no patch available

Race Condition Concepts

- **TOC (Time-of-check)** vs **TOU (Time-of-use)**: state changes between check and use
- **TOE**: Target of Evaluation

Identification Methods

- **Vulnerability scanning**: authenticated (credentialed) vs unauthenticated
- **Static analysis (SAST)**: scan source code
- **Dynamic analysis (DAST)**: scan running app
- **Package monitoring / SCA**: check third-party libraries
- **Threat feeds**: OSINT, proprietary, ISACs

- **Penetration testing**
- **Bug bounty / responsible disclosure**
- **Audits**

Web App Attack Types

- **SQL injection:** malicious SQL via user input
- **XSS:** inject scripts into pages viewed by others
 - **Stored** (persisted), **Reflected** (in URL), **DOM-based**
- **CSRF/XSRF:** trick authenticated user into an unintended action
- **Directory traversal:** ../ to escape web root
- **Command injection:** execute OS commands via vulnerable input

Analysis Concepts

- **CVE (Common Vulnerability Enumeration):** identifier (CVE-YYYY-NNNN)
- **CVSS (Common Vulnerability Scoring System):** 0-10 severity score
 - Low (0.1-3.9), Medium (4-6.9), High (7-8.9), Critical (9-10)
- **False positive:** flagged but not a real vuln
- **False negative:** real vuln, not flagged (worse)
- **Exposure factor:** percentage of asset value at risk
- **Environmental variables:** context-specific scoring

Response & Remediation

- **Patching** (primary remediation)
- **Compensating controls** when patching is not possible
- **Segmentation** to limit blast radius
- **Insurance** (transfer)
- **Exceptions / exemptions** (formal acceptance)

Validation

Rescan, audit, verification, then report.

Remember: A zero-day is a vulnerability the vendor does not yet know about; once disclosed it stops being a zero-day. Always validate scanner findings to weed out false positives before raising change tickets.

Lesson 9: Evaluate Network Security Capabilities

Maps to: 4.1 (Security Techniques on Computing Resources), 4.5 (Enterprise Capabilities)

Baselines & Benchmarks

- **Secure baseline:** known-good configuration
- **CIS Benchmarks, DISA STIGs, vendor hardening guides** are standard references
- **SCAP (Security Content Automation Protocol):** automate compliance scanning

Wireless Security

Protocol	Status
WEP	Broken, deprecated
WPA	Deprecated
WPA2	OK with strong PSK or 802.1X (AES-CCMP)
WPA3	Current standard, uses SAE (Simultaneous Authentication of Equals)

- **PSK (Pre-Shared Key):** personal mode
- **Enterprise mode:** 802.1X with RADIUS
- **WPS:** insecure, disable
- **Site survey:** plan AP placement
- **Heat map:** signal coverage

Wi-Fi Authentication

- **EAP-TLS:** mutual cert-based (strongest)
- **PEAP:** server cert, MS-CHAPv2 inside
- **EAP-TTLS:** similar to PEAP
- **EAP-FAST:** Cisco

Network Access Control (NAC)

- Enforce posture (patches, AV up to date) before granting access
- **802.1X-based** or **agent-based**

Access Control Lists (ACLs)

- Rule-based on source/destination IP, port, protocol

- Top-down evaluation, **implicit deny** at the end
- Order matters

IDS/IPS Detection Methods (recap)

- **Signature** vs **anomaly** vs **behaviour-based**
- **Trends:** baseline deviations over time
- **Heuristic:** rules-of-thumb classification

Web Filtering

- **Agent-based:** endpoint enforces
- **Centralised proxy / Secure Web Gateway:** all traffic via gateway
- **URL scanning, content categorisation, block rules, reputation**
- **DNS filtering:** block resolution of malicious domains (e.g. Cisco Umbrella, Quad9)

Remember: WPA3 uses SAE (a.k.a. Dragonfly) to fix WPA2's KRACK weakness and protect against offline dictionary attacks.

Lesson 10: Assess Endpoint Security Capabilities

Maps to: 2.5 (Mitigation Techniques), 4.1 (Secure Baselines), 5.6 (Awareness Practices)

Endpoint Hardening Techniques

- **Encryption:** Full Disk Encryption (FDE), Self-Encrypting Drives (SED)
- **Endpoint protection:** AV, anti-malware
- **Advanced endpoint:** EDR (Endpoint Detection and Response), XDR (Extended across multiple telemetry sources)
- **Host-based firewall**
- **Host-based IPS (HIPS)**
- **Disable unused ports and protocols**
- **Default password changes**
- **Removal of unnecessary software** (bloatware)
- **Group Policy** (Windows), **SELinux/AppArmor** (Linux)
- **Application allow-listing** (preferred over deny-listing)
- **Configuration enforcement / drift detection**
- **Patching**

Hardening Targets (per objectives)

Mobile, workstations, switches, routers, cloud infrastructure, servers, ICS/SCADA, embedded,

RTOS, IoT.

File Integrity Monitoring (FIM)

Tracks changes to critical files; alerts on tampering.

Mobile Device Management

Model	Who owns device	Who controls
BYOD	Employee	Mixed
COPE (Corporate-Owned, Personally Enabled)	Employer	Employer
CYOD (Choose Your Own Device)	Employer (from a list)	Employer
COBO (Corporate-Owned, Business Only)	Employer	Employer

- **MDM / UEM:** policy, push apps, remote wipe, containerise
- **Containerisation:** separate work data from personal
- **Full device encryption**
- **Location services:** geofencing, geolocation
- **Connection methods:** Cellular, Wi-Fi, Bluetooth, NFC, USB, tethering, hotspot

Mobile Threats

- **Sideload:** installing apps outside official stores
- **Jailbreaking/rooting:** removing OS restrictions
- **NFC/Bluetooth:** keep disabled when not in use; risk of bluejacking, bluesnarfing, bluebugging

Specialised Devices

Industrial controllers, medical, embedded, IoT often cannot run agents; rely on **network segmentation, monitoring, and compensating controls**.

Remember: EDR is host-focused; XDR correlates across endpoints, network, identity, cloud, and email.

Lesson 11: Enhance Application Security Capabilities

Maps to: 2.2 (Threat Vectors), 4.1 (App Security), 4.5 (Enterprise Capabilities)

Secure Protocol Cheat Sheet

Insecure	Secure	Port
Telnet	SSH	22
FTP	SFTP (over SSH), FTPS (over TLS)	22 / 990
HTTP	HTTPS (TLS)	443
POP3/IMAP	POP3S (995) / IMAPS (993)	
SMTP	SMTPS / STARTTLS	465 / 587
LDAP (389)	LDAPS (636)	
SNMPv1/v2	SNMPv3	161/162
DNS	DNSSEC, DoT (853), DoH	
RDP	RDP with TLS	3389

TLS Quick Facts

- Current: **TLS 1.3** (preferred), TLS 1.2 acceptable; **TLS 1.0/1.1 deprecated**
- Uses asymmetric for handshake, symmetric for bulk data
- **Cipher suite:** key exchange + signature + bulk encryption + MAC

Email Security Trio (must know)

Mechanism	What it does
SPF (Sender Policy Framework)	DNS record listing authorised senders
DKIM (DomainKeys Identified Mail)	Cryptographic signature in headers
DMARC	Policy on what to do when SPF/DKIM fail; alignment + reporting

Also: **S/MIME** and **PGP/GPG** for end-to-end email encryption and signing.

Email Threats & Controls

- **Spam filtering, attachment sandboxing, URL rewriting**
- **Email DLP** (prevent sensitive data leaving)
- **Secure email gateway**

Secure Coding Techniques

- **Input validation** (whitelisting preferred)
- **Output encoding** to defeat XSS
- **Parameterised queries / prepared statements** to defeat SQLi
- **Secure cookies:** HttpOnly, Secure, SameSite flags
- **Static code analysis (SAST)** during development
- **Dynamic code analysis (DAST)** against running app
- **Code signing**
- **Software sandboxing**
- **Software composition analysis** for libraries

Application Protections

- **WAF**
- **API gateways**
- **Rate limiting**
- **Secrets management** (no hard-coded credentials)

Remember: SPF says who **can** send; DKIM proves a message **was** sent legitimately; DMARC tells receivers **what to do** when SPF or DKIM fail.

Lesson 12: Explain Incident Response and Monitoring Concepts

Maps to: 4.4 (Alerting and Monitoring), 4.8 (Incident Response), 4.9 (Data Sources)

Incident Response Lifecycle (NIST)

1. **Preparation** (policies, tools, training)
2. **Detection / Identification** (alerts, anomalies)
3. **Analysis** (validate, scope, prioritise)
4. **Containment** (short-term and long-term)
5. **Eradication** (remove threat, clean systems)
6. **Recovery** (restore, monitor)
7. **Lessons Learned** (post-incident review, update playbooks)

Training & Testing

- **Tabletop exercise:** discussion
- **Simulation:** scripted walkthrough or technical drill
- **Threat hunting:** proactive, hypothesis-driven search for adversaries

Digital Forensics

- **Order of volatility** (most to least volatile):
 1. CPU registers, cache
 2. RAM
 3. Network state, running processes
 4. Disk
 5. Remote logs, archival media
- **Chain of custody:** documented who handled what, when (admissibility)
- **Legal hold:** preserve data when litigation likely
- **Acquisition:** create bit-by-bit images (write blocker, hash before/after)
- **Preservation:** integrity hashes (MD5/SHA-256) match
- **E-discovery:** identify and produce ESI for legal matters
- **Reporting:** clear, factual, reproducible

Acquisition Order

1. System memory (RAM) before powering off
2. Disk image (full forensic copy)
3. Logs and external sources

Log Sources

- **Firewall, IDS/IPS, network, application, endpoint, OS security, DNS, web server, authentication**
- **Metadata:** time, user, source, action
- **Packet captures (PCAP):** raw network data via Wireshark, tcpdump

SIEM, SOAR, and Friends

- **SIEM:** aggregates and correlates logs, alerts on patterns
- **SOAR:** Security Orchestration, Automation, and Response (playbooks)
- **UEBA / User Behaviour Analytics:** detect anomalous user activity
- **SCAP:** automate vulnerability and compliance content
- **NetFlow:** summarised traffic data (who talked to whom, how much)
- **SNMP traps:** asynchronous network event notifications

Alert Tuning

Reduce noise, suppress known-benign, prioritise high-fidelity detections. Goal: high signal, low

alert fatigue.

Remember: Volatile data first. Image before analysis. Hash everything to prove integrity.

Lesson 13: Analyse Indicators of Malicious Activity

Maps to: 2.4 (Indicators of Malicious Activity)

Malware Classification

Type	Description
Virus	Attaches to host file, needs execution
Worm	Self-propagating across networks
Trojan	Disguised as legitimate software
Ransomware	Encrypts data, demands payment
Crypto-malware	Mines cryptocurrency on victim resources
Spyware	Covert surveillance
Keylogger	Records keystrokes
Rootkit	Kernel/firmware-level, hides itself
Backdoor / RAT	Remote access for attacker
Logic bomb	Triggered by condition or date
Fileless malware	Lives in memory; no disk artefacts
Bloatware	Pre-installed unwanted but not malicious
PUP	Potentially Unwanted Programme

TTPs & IoCs

- **TTPs:** Tactics, Techniques, Procedures (e.g. MITRE ATT&CK)
- **IoCs:** Indicators of Compromise (file hashes, IPs, domains, behaviours)
- **IoAs:** Indicators of Attack (in-progress behaviour)

Malicious Activity Indicators

- Account lockout, concurrent session usage

- Blocked content, impossible travel
- Resource consumption (CPU, memory, bandwidth spikes)
- Resource inaccessibility
- Out-of-cycle logging
- Published/documented indicators (vendor advisories)
- Missing logs (sign of tampering)

Physical Attacks

- **Brute force:** physical access attempts
- **RFID cloning**
- **Environmental:** HVAC, power, fire suppression tampering

Network Attacks

- **DDoS:** Distributed Denial of Service
 - **Amplified:** small request, large response (DNS, NTP, memcached)
 - **Reflected:** spoofed source so reply hits victim
- **DNS attacks:** poisoning, hijacking, tunnelling, DNS rebinding
- **On-path (Man-in-the-Middle):** intercept and possibly alter traffic
- **Wireless:** evil twin, rogue AP, deauth, jamming
- **Credential replay:** capture and re-send credentials
- **Pass-the-hash, Pass-the-ticket**
- **Cryptographic attacks:** downgrade (e.g. POODLE), collision, birthday

Password Attacks

- **Brute force:** try every combination
- **Dictionary:** try common words
- **Spraying:** one password across many accounts (evades lockout)
- **Rainbow tables:** precomputed hashes (defeated by salting)

Application Attack Indicators

- **Injection:** SQLi, command injection, LDAP injection
- **Buffer overflow:** write past memory bounds
- **Replay:** reuse captured token/session
- **Privilege escalation:** vertical (admin) or horizontal (other user)
- **Forgery:** CSRF, request forgery, session forgery
- **Directory traversal:** ../ to access outside web root

- **URL analysis:** look for encoded payloads, anomalies
- **Web server logs:** 404 spray, 500 errors, large response sizes

Remember: Worms self-propagate, viruses do not. Fileless malware leaves no disk trace, so memory analysis matters.

Lesson 14: Summarise Security Governance Concepts

Maps to: 1.3 (Change Management), 4.7 (Automation), 5.1 (Governance)

Governance Documents Hierarchy

1. **Policies:** high-level intent (what)
2. **Standards:** mandatory specifics (how must)
3. **Procedures:** step-by-step (how to)
4. **Guidelines:** recommended (how should)
5. **Playbooks:** scenario-specific procedures

Common Policy Types

- **Acceptable Use Policy (AUP)**
- **Information Security Policy**
- **Business Continuity Policy**
- **Disaster Recovery Policy**
- **Incident Response Policy**
- **SDLC Policy**
- **Change Management Policy**
- **Password Policy, Access Control Policy, Encryption Policy**

Roles & Responsibilities

- **Data owner:** accountable for the data (business)
- **Data controller:** decides why and how data is processed (GDPR / Privacy Act term)
- **Data processor:** processes on behalf of the controller
- **Data custodian/steward:** maintains and protects (IT)
- **Data Privacy Officer (DPO):** privacy programme oversight

External Considerations

Regulatory, legal, industry, local/regional, national, global. In AU/NZ context: Privacy Act 1988 (Cth), APP, OAIC, Australian Cyber Security Centre Essential Eight, ISM, IRAP, Privacy Act 2020 (NZ).

Governance Structures

Boards, committees, government entities, centralised vs decentralised. In a vCISO engagement, you typically embed within or report into one of these.

Change Management Programme

- **Approval process** (CAB / Change Advisory Board)
- **Ownership** and stakeholders
- **Impact analysis**
- **Test results**
- **Backout plan** (rollback)
- **Maintenance window**
- **Standard Operating Procedure (SOP)**

Technical Implications

- Allow lists/deny lists
- Restricted activities
- Downtime, service restart, application restart
- Legacy applications and dependencies
- Documentation: update diagrams, policies, procedures
- **Version control** for documentation and code

Automation and Orchestration

Use cases: user provisioning, resource provisioning, guard rails, security groups, ticket creation, escalation, enabling/disabling services and access, continuous integration and testing, API integrations.

Benefits: efficiency, enforcing baselines, standard configurations, secure scaling, employee retention, faster reaction time, workforce multiplier.

Considerations: complexity, cost, single point of failure, technical debt, ongoing supportability.

Remember: Standards are mandatory; guidelines are recommended. A documented backout plan is mandatory for any production change in audit-friendly programmes.

Lesson 15: Explain Risk Management Processes

Maps to: 5.2 (Risk Management), 5.3 (Third-Party Risk), 5.5 (Audits/Assessments)

Risk Management Process

1. **Identify** risks
2. **Assess** (qualitative and/or quantitative)
3. **Analyse** likelihood and impact
4. **Respond / treat**
5. **Monitor and review**

Risk Analysis Approaches

Approach	Description
Qualitative	Subjective (High/Medium/Low matrix)
Quantitative	Numeric, monetary

Quantitative Formulas (MEMORISE)

- **SLE (Single Loss Expectancy)** = Asset Value x Exposure Factor (EF)
- **ALE (Annualised Loss Expectancy)** = SLE x ARO
- **ARO (Annualised Rate of Occurrence)** = expected occurrences per year

Example: Server worth \$50,000. Fire would destroy 60 percent (EF = 0.6). Fire happens once every 25 years (ARO = 0.04). SLE = \$30,000. ALE = \$1,200/year.

Risk Treatment Strategies (the 4 Ts/As)

Strategy	Action
Avoid	Stop the activity creating the risk
Transfer (Share)	Insurance, outsourcing
Mitigate (Reduce)	Apply controls to lower risk
Accept	Acknowledge and live with it (with exemption or exception)

Risk Register Components

- Risk description
- Risk owner
- Likelihood, impact, inherent and residual risk
- **Key Risk Indicators (KRIs)**

- **Risk threshold**
- Treatment plan, status

Risk Appetite

- **Expansionary:** higher tolerance for risk
- **Conservative:** lower tolerance
- **Neutral:** balanced

Business Impact Analysis (BIA)

Identifies critical functions and the impact of disruption. Drives RTO, RPO, MTTR, MTBF.

Third-Party Risk

- **Vendor assessment:** penetration testing, right-to-audit clause, evidence of internal audits (SOC 2, ISO 27001 certs), independent assessments, supply chain analysis
- **Due diligence** before signing
- **Conflict of interest** checks
- **Continuous vendor monitoring**

Agreements & Documents

Acronym	Meaning
NDA	Non-Disclosure Agreement
SLA	Service-Level Agreement (uptime, support)
MOA	Memorandum of Agreement
MOU	Memorandum of Understanding
MSA	Master Service Agreement
SOW / WO	Statement of Work / Work Order
BPA	Business Partners Agreement
DPA	Data Processing Agreement (GDPR-style)

Audits & Assessments

- **Internal audit:** by the organisation
- **External audit:** independent third party

- **Attestation:** formal statement that controls are in place (SOC 2 reports are attestations)
- **Regulatory examinations**

Penetration Testing

Approach	Description
Known environment (white-box)	Tester has full info
Partially known (grey-box)	Tester has limited info
Unknown (black-box)	Tester has no inside info
Physical / Offensive / Defensive / Integrated	Scope dimensions

- **Reconnaissance: Passive** (no direct interaction) vs **Active** (probes the target)
- **Rules of engagement** must be agreed up front

Exercises

- **Tabletop, simulation, parallel, full failover**
- **Red team** (attack), **Blue team** (defend), **Purple team** (collaborative)

Remember: $SLE \times ARO = ALE$. SOC 2 Type II covers operating effectiveness over a period (typically 6-12 months); IRAP is the Australian assurance approach for handling government information.

Lesson 16: Summarise Data Protection and Compliance Concepts

Maps to: 3.3 (Data Protection), 5.4 (Compliance), 5.6 (Awareness)

Data Types

- **Regulated** (PII, PHI, PCI)
- **Trade secret**
- **Intellectual property**
- **Legal, Financial**
- **Human-readable vs non-human-readable**

Data Classifications

- **Public:** no restrictions
- **Private / Internal:** within the organisation

- **Sensitive / Confidential:** restricted to authorised parties
- **Restricted / Critical:** highest protection
- Government variants: Unclassified, Confidential, Secret, Top Secret. AU PSPF uses: OFFICIAL, OFFICIAL: Sensitive, PROTECTED, SECRET, TOP SECRET.

Data States

- **Data at rest:** stored (FDE, file/database encryption)
- **Data in transit:** moving (TLS, IPSec)
- **Data in use:** being processed (memory encryption, confidential computing)

Data Sovereignty & Geolocation

Data is subject to the laws of the country it resides in. Cross-border transfer may require contractual safeguards (Standard Contractual Clauses, APP 8 disclosure to overseas recipients in AU).

Methods to Secure Data

- **Encryption** (at rest, in transit, in use)
- **Hashing** for integrity
- **Masking** (XXX-XX-1234)
- **Tokenisation** (replace with non-sensitive token, vault maps back)
- **Obfuscation** (general term for hiding meaning)
- **Segmentation** (network and data isolation)
- **Permission restrictions**
- **Geographic restrictions**

Privacy Concepts

- **Data subject:** the person the data is about
- **Controller vs processor:** controller decides purpose and means; processor acts on instructions
- **Ownership**
- **Data inventory and retention** schedules
- **Right to be forgotten / erasure** (GDPR Article 17)

Major Privacy/Compliance Frameworks (for context)

- **GDPR** (EU)
- **Privacy Act 1988** and APPs (AU)
- **Privacy Act 2020** (NZ)
- **HIPAA** (US healthcare)

- **PCI DSS** (payment cards)
- **SOX** (financial reporting)
- **ISO 27001** (ISMS), **SOC 2** (Trust Services Criteria)
- **IRAP, Essential Eight, ISM** (AU government)

Compliance Reporting

- **Internal vs external**
- **Consequences of non-compliance:** fines, sanctions, reputational damage, loss of license, contractual impacts

Compliance Monitoring

- **Due diligence / due care**
- **Attestation and acknowledgement**
- **Internal and external monitoring**
- **Automation** (continuous compliance via tooling)

Data Loss Prevention (DLP)

- Detects and blocks unauthorised data movement
- **Endpoint DLP, Network DLP, Cloud DLP, Email DLP**
- Identifies via patterns (regex), classifiers, fingerprints, watermarks

Personnel Policies

- **Acceptable use, conduct, code of ethics**
- **Onboarding/offboarding**
- **Job rotation, mandatory holidays, separation of duties** (detect fraud)
- **NDA, background checks**
- **Clean desk policy**

Security Awareness Training

- **Initial** training at onboarding
- **Recurring** annual or quarterly
- **Role-based** (developer secure coding, executive awareness, etc.)
- **Phishing campaigns** to test and educate
- **Anomalous behaviour recognition:** risky, unexpected, unintentional
- **Lifecycle:** Develop, Execute, Report, Monitor, Iterate

Topics for Training

Insider threat, password management, removable media and cables, social engineering, operational security, hybrid/remote work environments, situational awareness.

Remember: Tokenisation replaces sensitive data with a non-sensitive surrogate that maps back via a vault; masking only hides during display. GDPR is opt-in; many US laws are opt-out; APPs in Australia define a consent-and-purpose model.

Appendix A: High-Yield Acronyms

Acronym	Meaning
AAA	Authentication, Authorization, Accounting
AES	Advanced Encryption Standard
ALE / SLE / ARO	Annualised Loss Expectancy / Single Loss Expectancy / Annualised Rate of Occurrence
APT	Advanced Persistent Threat
ASLR	Address Space Layout Randomisation
AUP	Acceptable Use Policy
BIA	Business Impact Analysis
BYOD / COPE / CYOD	Bring Your Own / Corporate-Owned, Personally Enabled / Choose Your Own Device
CA / CRL / OCSP / CSR	Certificate Authority / Revocation List / Online Cert Status Protocol / Cert Signing Request
CASB	Cloud Access Security Broker
CIA	Confidentiality, Integrity, Availability
CSRF / XSRF	Cross-Site Request Forgery
CVE / CVSS	Common Vulnerability Enumeration / Scoring System
DAC / MAC / RBAC / ABAC	Discretionary / Mandatory / Role-Based / Attribute-Based Access Control
DKIM / SPF / DMARC	Email authentication trio
DLP	Data Loss Prevention

Acronym	Meaning
DDoS / DoS	(Distributed) Denial of Service
EAP / PEAP / EAP-TLS	Extensible Authentication Protocol variants
EDR / XDR / MDR	Endpoint / Extended / Managed Detection and Response
FDE / SED	Full Disk Encryption / Self-Encrypting Drive
FIM	File Integrity Monitoring
HIDS / HIPS / NIDS / NIPS	Host/Network IDS/IPS
HSM / TPM	Hardware Security Module / Trusted Platform Module
IaaS / PaaS / SaaS / FaaS	Cloud service models
IaC	Infrastructure as Code
IDS / IPS	Intrusion Detection / Prevention System
IoC / IoA	Indicator of Compromise / Attack
IPSec / IKE / ESP / AH	IPSec protocol suite
LDAP / LDAPS	Lightweight Directory Access Protocol
MFA / SSO	Multifactor Authentication / Single Sign-On
MTBF / MTTR / RTO / RPO	Reliability and recovery metrics
NAC	Network Access Control
NGFW / WAF / UTM	Firewall types
OAuth / OIDC / SAML	Federated identity protocols
OSINT	Open-Source Intelligence
PAM	Privileged Access Management (and Pluggable Authentication Modules)
PKI	Public Key Infrastructure
PFS	Perfect Forward Secrecy
PHI / PII / PCI	Protected Health Info / Personally Identifiable Info / Payment Card Industry
RADIUS / TACACS+	AAA protocols

Acronym	Meaning
RAT	Remote Access Trojan
SAE	Simultaneous Authentication of Equals (WPA3)
SASE / SD-WAN / SDN	Network architecture concepts
SCAP	Security Content Automation Protocol
SIEM / SOAR	Security analytics platforms
SOC	Security Operations Centre (also SOC 2 audit report)
SSO	Single Sign-On
STIX / TAXII	Threat intelligence formats
TLS / SSL	Transport Layer Security / Secure Sockets Layer (deprecated)
TOTP / HOTP	Time/HMAC-based One-Time Password
TTP	Tactics, Techniques, Procedures
UPS / PDU	Uninterruptible Power Supply / Power Distribution Unit
VPN / VPC	Virtual Private Network / Virtual Private Cloud
WPA2 / WPA3 / WEP / WPS	Wi-Fi security

Appendix B: Common Ports

Service	Port	Notes
FTP	20/21	Insecure
SSH / SFTP	22	Encrypted
Telnet	23	Insecure, avoid
SMTP	25	Use 465/587 with TLS
DNS	53	TCP for zone transfers, UDP for queries
DHCP	67/68	
TFTP	69	Insecure

Service	Port	Notes
HTTP	80	
Kerberos	88	
POP3 / POP3S	110 / 995	
NTP	123	
NetBIOS	137-139	
IMAP / IMAPS	143 / 993	
SNMP / SNMP Trap	161 / 162	v3 preferred
LDAP / LDAPS	389 / 636	
HTTPS	443	
SMB	445	
IKE / IPSec NAT-T	500 / 4500	
Syslog	514	
SMTPS	465 (legacy), 587 (submission)	
LDAP over TLS	636	
FTPS (control/data)	989 / 990	
RDP	3389	
MS SQL	1433	
MySQL	3306	
Oracle	1521	
RADIUS	1812 / 1813 (acct)	
TACACS+	49	
SIP	5060 / 5061 (TLS)	

Appendix C: Exam Day Quick Tips

1. **Read the question stem twice.** Performance-Based Questions (PBQs) appear early; flag

and return if needed.

2. **Look for keywords:** "BEST", "MOST", "FIRST", "LEAST" change the right answer entirely.
3. **Eliminate clearly wrong answers** to improve odds.
4. **If two answers seem right, pick the one that addresses the root cause** or the broader principle.
5. **Confidentiality / integrity / availability** maps to almost every scenario. Identify which is the primary concern.
6. **Defence in depth:** if the question implies "layered", that is likely a clue.
7. **Least privilege and separation of duties** are the default correct answers for many access control questions.
8. **For incident response order:** Preparation, Detection, Analysis, Containment, Eradication, Recovery, Lessons Learned.
9. **For forensics:** order of volatility, chain of custody, hash before and after.
10. **For risk treatment:** if cost of mitigation > impact, **accept** with documented exception; otherwise **mitigate, transfer, or avoid**.

Good luck.

Aligned to CompTIA Security+ SY0-701 Exam Objectives v2.0. Not affiliated with or endorsed by CompTIA.